CardioAI — Relatório Técnico de Governança e Auditoria Médica

Desafio Ir Além 1: Camada de Governança, Rastreabilidade e Auditoria em Sistemas Multiagente

FIAP — Fase 6: Coração Sob Controle | **Disciplina:** Governança, Boas Práticas e Arquitetura de IA (GBA)
Integrantes: Jonas Luis da Silva (RM561465) & Edson Henrique Felix Batista (RM566321)

1. Registro Estruturado de Decisões e Telemetria Nativa (OpenAI Agents SDK)

Em aplicações de Inteligência Artificial para saúde, a auditoria não pode depender de parsing volátil de texto no terminal. No CardioAI, a classe AuditRunHooks herda de RunHooks do **OpenAI Agents SDK** para interceptar callbacks nativos assíncronos (on_agent_start, on_handoff, on_tool_start e on_tool_end). Cada deliberação é persistida de forma append-only no arquivo logs/decisoes.jsonl com UUIDv4 exclusivo, carimbo temporal ISO-8601, integridade criptográfica SHA-256 dos dados brutos, sequência comprovada de handoffs entre agentes, ferramentas executadas com seus parâmetros e saídas, validação de coerência e status do guardrail.


```
{
  "id_decisao": "a7d58a73-b0fa-40df-b99a-864587987470", "timestamp": "2026-10-15T20:33:57.303Z",
  "session_id": "audit_novo_caso_9a5a85", "hash_dados_entrada": "3a89b22083c1a61063685a2893ee076f...b8",
  "dados_paciente": {"idade": 62, "carga_sistema": 92%, "spo2": 89%, "pa_sistolica": 100, "densidade_eventos": 7, ...},
  "modelo_preditivo": {"nome": "RandomForestClassifier", "sklearn_version": "1.9.0", "accuracy": 0.999, "f1_score": 0.9981},
  "probabilidade": 0.99, "classificacao": "ALTO", "guardrail_status": "aprovado",
  "protocolos_sugeridos": ["Carga > 85% -> unidades temporárias", "Recursos < 30% -> redistribuir insumos",
                           "Densidade > 6 -> contingência", "Risco sistêmico alto -> estado de emergência"],
  "sequencia_handoffs": ["Orquestrador -> Analista de Risco", "Analista de Risco -> Esp. Protocolos", "Esp. Protocolos -> Planejador"],
  "tools_chamadas": ["prever_risco_paciente (concluido)", "consultar_base_protocolos (concluido)"],
  "validacao_coerencia": {"coerente": true, "inconsistencias": []}
}
```


2. Validação Determinística de Coerência Clínica (`coherence_validator.py`)

Para blindar a decisão médica contra alucinações de modelos de linguagem, o CardioAI emprega o coherence_validator.py. O validador **reutiliza estritamente as diretrizes de src/protocols.py e limiares de src/config.py sem duplicar código**, operando como uma barreira regulamentar determinística que avalia quatro invariantes assistenciais:

• **Regra A (Condição Crítica Real):** Cada protocolo sugerido deve ter sua variável clínica ou operacional estritamente acima/abaixo do limiar regulamentar. Protocolos inventados ou ativados sem critério objetivo são reprovados.
• **Regra B (Prevenção de Omissão de Conduta):** Nenhum protocolo que as diretrizes determinísticas exijam pode ficar de fora da recomendação final sintetizada pelo agente consolidador.
• **Regra C (Conformidade com Limiares de Machine Learning):** O score de probabilidade inferido deve mapear perfeitamente para a classe correspondente (<0.30 BAIXO, 0.30–0.70 MODERADO, >0.70 ALTO).
• **Regra D (Biunivocidade de Emergência Sistêmica):** A classificação ALTO exige compulsoriamente a ativação de *'Se risco sistêmico alto → ativar estado de emergência'*; em contrapartida, pacientes BAIXO ou MODERADO não podem conter esse protocolo sob hipótese alguma.

3. Detecção em Teste de Adulteração e Rastreabilidade Criptográfica

Evidência do Teste Controlado de Adulteração (run_auditado.py):
Para comprovar a robustez da governança, simulou-se a inserção fraudulenta da conduta de oxigenoterapia *'Se SPO2 < 88% → iniciar suporte respiratório imediato'* na decisão do **novo_caso** (SpO2 real: 89.0%).
Resultado do Validador: coerente: false | **Inconsistência capturada:** *'Protocolo indevido (Regra A): sugerido mas dados vitais não atingem o limiar de acionamento'*. Status no log gravado como **reprovado_por_coerencia**.

A rastreabilidade é fundamentada em três pilares criptográficos e estruturais:
• **Hash SHA-256 de Entrada:** As 10 variáveis do paciente são serializadas em JSON canônico ordenado. O hash resultante (ex: 3a89b22...1ab8) impede alteração retroativa dos sinais vitais utilizados na decisão (non-repudiation).
• **Metadados do Modelo (.joblib):** A função obter_metadados_modelo() lê dinamicamente do arquivo binário a versão do Scikit-Learn (1.9.0), data de treino e métricas auditáveis (Acurácia: 99,9%, F1-Score: 0,9981).
• **Auditoria Interativa (CLI):** O script consultar_auditoria.py permite inspecionar decisões, filtrar por sessão, classe ou flag de incoerência.

4. Princípios de Governança em Saúde e Mapeamento Concreto no Código

A governança de inteligência artificial em ambientes hospitalares transcende aspectos puramente técnicos, alinhando-se a preceitos bioéticos e legislações vigentes (LGPD, Resoluções CFM e diretrizes internacionais de Software as a Medical Device — SaMD):

Princípio Ético / Legal	Exigência Regulamentar na Saúde	Componente Concreto no CardioAI
Explicabilidade (Explainability)	O profissional médico precisa compreender os fatores que motivaram o score e as regras de contingência.	cardio_agents.py instrui o Planejador a justificar cada ação pelas variáveis críticas; coherence_validator.py garante fidelidade aos fatos.
Accountability & Rastreabilidade	Cadeia ininterrupta de custódia das decisões: quem inferiu, quando, quais ferramentas foram executadas e quem aprovou.	audit_logger.py grava log append-only com hash SHA-256 da entrada, métricas do .joblib, UUIDv4 e sequência real de handoffs via AuditRunHooks.
LGPD & Minimização de Dados	Uso estrito dos dados indispensáveis ao atendimento, vedando exposição de dados sensíveis e PII desnecessárias.	data_generation.py gera dados sintéticos controlados; o pipeline transaciona exclusivamente 10 variáveis numéricas sem identificadores civis ou PII.
Humano no Loop (Human-in-the-Loop)	A IA não substitui a soberania médica, vedando diagnósticos definitivos ou prescrições automáticas sem validação.	Guardrail em guardrails.py e avisos em schemas.py garantem suporte analítico a risco operacional, alertando que o sistema não emite diagnóstico.

Conclusão: A camada de governança do CardioAI assegura total conformidade regulamentar, integridade determinística e auditabilidade completa, viabilizando o uso seguro de sistemas multiagente em ambientes hospitalares críticos.